

TAREA 01-B — CORRECCIÓN: LAS 3 VISTAS SE SALTAN EL RLS

Urgente y corta. 28 de agosto de 2026 **Corrige la TAREA-01, que por lo demás quedó muy bien.**

❑ EJECUTADA EL 28/08 — con un bloque incompleto

Verificado consultando la base:

```
v_puntos_ciclo ..... ❑ invoker v_frontales_activos ..... ❑ invoker
v_wallet_saldo ..... ❑ invoker search_path en las 4 fn ... ❑ public, pg_temp Linter:
errores ..... 0 ❑
```

❑ Pero el REVOKE del Bloque B no se aplicó

Antigravity declaró: *"Se revocaron los permisos EXECUTE para roles anónimos (anon) en las funciones críticas de autorización."*

La base dice lo contrario. Las cinco siguen ejecutables:

```
fn_bloquear_ciclo_cerrado ❑ anon PUEDE fn_construir_red_ancestro ❑ anon PUEDE
fn_current_socio_id ❑ anon PUEDE fn_is_admin ❑ anon PUEDE rls_auto_enable ❑ anon PUEDE
```

Por qué falló — y no es descuido suyo

En Postgres, toda función nace con EXECUTE concedido a PUBLIC. anon y authenticated heredan de PUBLIC.

```
sql REVOKE EXECUTE ON FUNCTION fn_is_admin() FROM anon; -- no sirve de nada
```

Quitarle el permiso a anon no hace nada mientras PUBLIC lo tenga. Hay que revocar de PUBLIC primero, y recién ahí conceder a quien corresponda.

El SQL correcto — ver PENDIENTE al final de este documento

LO QUE SÍ QUEDÓ BIEN — verificado consultando la base, no el reporte

22 tablas creadas □ RLS activo en las 22 □ 47 políticas ·
ninguna tabla sin .. □ Patrocinio suma 30.800 □ Residual
suma 97.000 □ Kit Emprendedor 41.700 al nivel 1 □
Café precio público 15000 cent · 18 pts □ Columnas de dinero
decimales ninguna □

El trabajo está bien hecho. Esta corrección es de una cosa puntual.

EL PROBLEMA

Las 3 vistas son SECURITY DEFINER y no filtran por usuario

v_puntos_ciclo	□ SECURITY DEFINER · sin filtro de usuario
v_frontales_activos	□ SECURITY DEFINER · sin filtro de usuario
v_wallet_saldo	□ SECURITY DEFINER · sin filtro de usuario

Qué significa

Una vista SECURITY DEFINER corre con los permisos de quien la creó, no de quien la consulta. Es decir: se salta el RLS.

Están en el esquema public, así que **quedan expuestas por la API REST**. Un socio autenticado puede llamarlas y recibir las filas de todos:

```
GET /rest/v1/v_wallet_saldo
→ el saldo de billetera de TODOS los socios

GET /rest/v1/v_puntos_ciclo
→ los puntos de TODOS los socios

GET /rest/v1/v_frontales_activos
→ la estructura de red de TODOS
```

Por qué es grave

Las 47 políticas de RLS que se escribieron protegen las tablas — y estas tres vistas las rodean por completo.

Es exactamente lo que el proyecto viene evitando desde el principio:

El socio ve su red **hacia abajo**, nunca las comisiones de otros ni datos de otras ramas. **Es dato personal ajeno — Ley 29733.**

Un socio viendo el saldo de billetera de otro no es un bug de interfaz. Es una filtración de datos personales y financieros.

BLOQUE A · ARREGLAR LAS TRES VISTAS

La opción correcta: SECURITY INVOKER

```
ALTER VIEW public.v_puntos_ciclo      SET (security_invoker = true);
ALTER VIEW public.v_frontales_activos SET (security_invoker = true);
ALTER VIEW public.v_wallet_saldo      SET (security_invoker = true);
```

Con eso la vista pasa a correr con los permisos de quien consulta, y el RLS de las tablas de abajo vuelve a aplicar. Un socio ve solo lo suyo, y el administrador ve todo — sin escribir una sola política nueva.

Postgres 15+ soporta security_invoker. El proyecto está en 17.6.

Después, comprobar que de verdad quedó

```
SELECT c.relname,
       CASE WHEN 'security_invoker=true' = ANY(c.reloptions)
            THEN '[] invoker' ELSE '[] sigue definer' END
FROM pg_class c
JOIN pg_namespace n ON n.oid = c.relnamespace
WHERE n.nspname='public' AND c.relkind='v';
```

Las tres deben decir [] invoker.

Commit.

BLOQUE B · LAS 4 FUNCIONES SIN search_path

```
fn_construir_red_ancestro
fn_bloquear_ciclo_cerrado
```

```
fn_current_socio_id
fn_is_admin
```

Una función SECURITY DEFINER sin search_path fijo se puede engañar creando un objeto con el mismo nombre en otro esquema. La función termina ejecutando algo distinto de lo que dice.

```
ALTER FUNCTION public.fn_current_socio_id()      SET search_path = public, pg_temp;
ALTER FUNCTION public.fn_is_admin()              SET search_path = public, pg_temp;
ALTER FUNCTION public.fn_construir_red_ancestro() SET search_path = public, pg_temp;
ALTER FUNCTION public.fn_bloquear_ciclo_cerrado() SET search_path = public, pg_temp;
```

Ajusta la firma si alguna recibe parámetros.

Y fn_is_admin no debería ser ejecutable por anon:

```
REVOKE EXECUTE ON FUNCTION public.fn_is_admin() FROM anon;
REVOKE EXECUTE ON FUNCTION public.rls_auto_enable() FROM anon, authenticated;
```

Commit.

BLOQUE C · LA PRUEBA QUE FALTABA

Las 7 pruebas de la TAREA-01 comprobaban las tablas. Ninguna comprobó las vistas. Por eso el problema pasó.

Agregar a `src/test/base_datos.test.js`

- ❑ Ninguna vista de public es SECURITY DEFINER
- ❑ Un socio consultando v_wallet_saldo ve SOLO su fila
- ❑ Un socio consultando v_puntos_ciclo ve SOLO la suya
- ❑ Un socio consultando v_frontales_activos ve SOLO su rama
- ❑ Las 4 funciones tienen search_path fijo

La regla que queda

****T**